



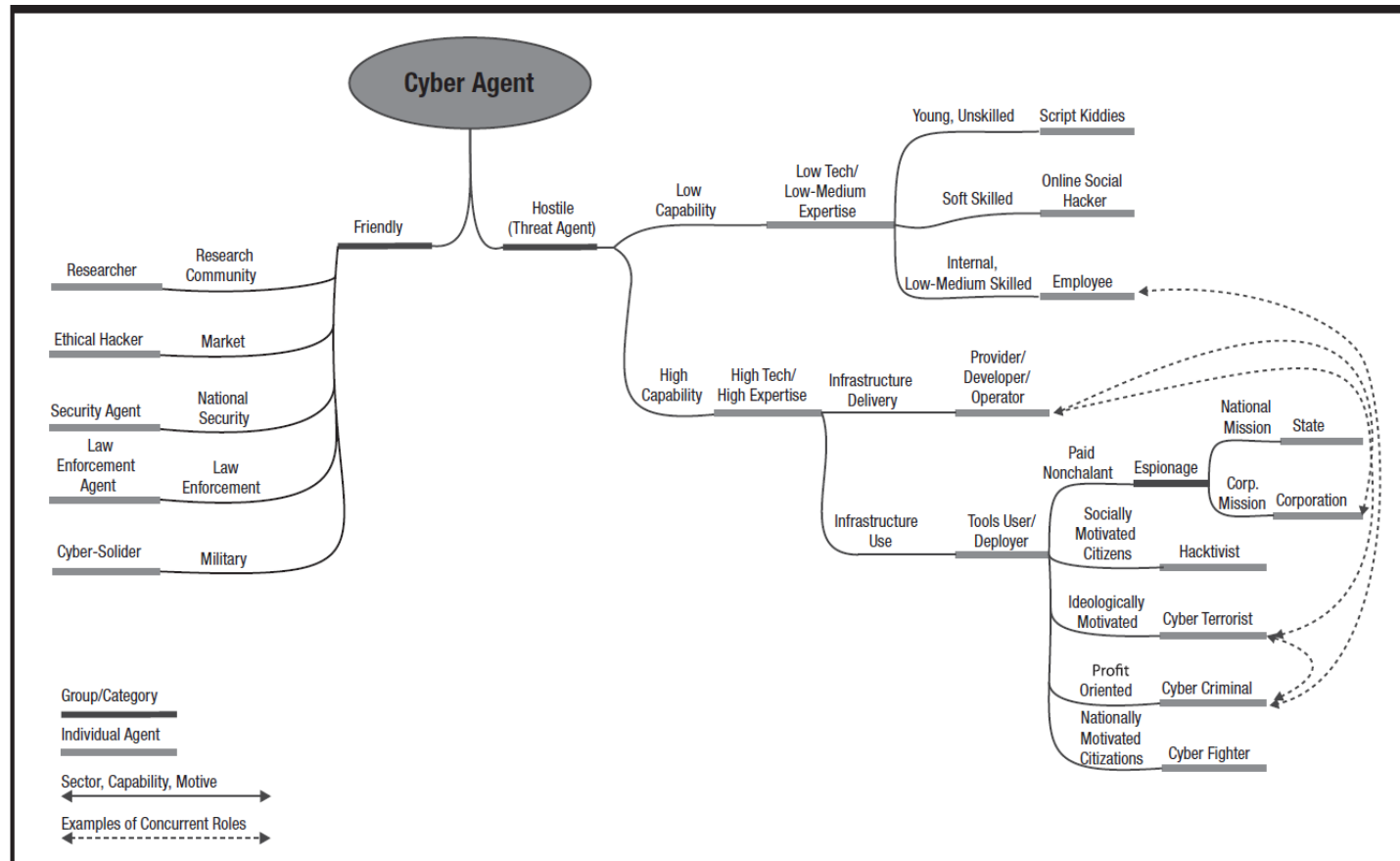
Lecture 2

Cybersecurity threats

Common Attack Types and Vectors

- As attack vectors and methodologies continue to evolve, they represent a significant threat on the client side.
- Although some attacks are made at random with no particular target in mind, there are also targeted attacks against recipients who have been researched and identified as useful by attackers.
- A cyberattack is a well-defined, advanced, targeted attack that is stealthy and has a mission that it will not stop attempting to achieve until it is identified and mitigated or succeeds.
- In today's threat landscape, a number of distinct threat agents and attack patterns have emerged. It is essential for cybersecurity professionals to be able to identify these threats in order to manage them appropriately.

Threat Agents



Threat Agents

- Corporations—Corporations have been known to breach security boundaries and perform malicious acts to gain a competitive advantage.
- Nation States—Nation states often target government and private entities with a high level of sophistication to obtain intelligence or carry out other destructive activities.
- Hacktivists—Although they often act independently, politically motivated hackers may target specific individuals or organizations to achieve various ideological ends.
- Cyberterrorists—Characterized by their willingness to use violence to achieve their goals, cyberterrorists frequently target critical infrastructures and government groups

Threat Agents

- Cybercriminals—Motivated by the desire for profit, these individuals are involved in fraudulent financial transactions.
- Cyberwarriors—Often likened to hacktivists, cyberwarriors, also referred to as cyberfighters, are nationally motivated citizens who may act on behalf of a political party or against another political party that threatens them.
- Script Kiddies—Script kiddies are young individuals who are learning to hack; they may work alone or with others and are primarily involved in code injections and distributed denial-of-service (DDoS) attacks.
- Online Social Hackers—Skilled in social engineering, these attackers are frequently involved in cyberbullying, identity theft and collection of other confidential information or credentials.
- Employees—Although they typically have fairly low-tech methods and tools, dissatisfied current or former employees represent a clear cybersecurity risk.

Attack Attributes

- An attack is an activity by a threat agent (or adversary) against an asset.
- From an attacker's point of view, the asset is a target, and the path or route used to gain access to the target (asset) is known as an attack vector.
- There are two types of attack vectors: ingress and egress (also known as data exfiltration).
- The attacker must defeat any controls in place and/or use an exploit to take advantage of a vulnerability.
- Another attribute of an attack is the attack mechanism, or the method used to deliver the exploit. Unless the attacker is personally performing the attack, the attack mechanism may involve a payload, or container, that delivers the exploit to the target.

Attack Attributes

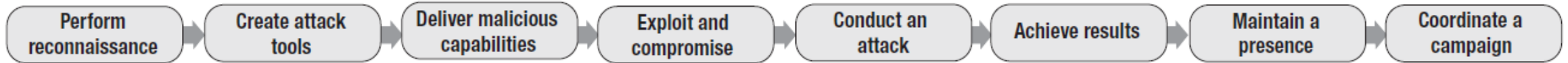
- Detailed analysis of cyberattacks requires significant technical and subject matter expertise and is an important part of cybersecurity.
- Each of the attack attributes (attack vector, payload, exploit, vulnerability, target and, if applicable, egress) provides unique points where controls to prevent or detect the attack can be placed.
- It is also essential to understand each of these attributes when analyzing and investigating an actual attack.



Attack Attributes

- Analysis of the data exfiltration path may identify additional opportunities to prevent or detect the removal of data or obtain evidence, even if the attack was able to gain access to the target.
- Attacks can be analyzed and categorized based on their type and patterns of use.
- From these characteristics, it is possible to make generalizations that facilitate better design and controls.
- There are two broad categories for threat events: adversarial and nonadversarial.
- An adversarial threat event is made by a human threat agent (or adversary), while a nonadversarial threat event is usually the result of an error, malfunction or mishap of some sort.

Generalized Attack Process



1. Perform reconnaissance: The adversary gathers information using a variety of techniques, which may include:
 - Sniffing or scanning the network perimeter
 - Using open source discovery of organizational information
 - Running malware to identify potential targets
2. Create attack tools: The adversary crafts the tools needed to carry out a future attack, which may include:
 - Phishing or spear phishing attacks
 - Crafting counterfeit web sites or certificates
 - Creating and operating false front organizations to inject malicious components into the supply chain

Generalized Attack Process

3. Deliver malicious capabilities: The adversary inserts or installs whatever is needed to carry out the attack, which may include the following tactics:
 - Introducing malware into organizational information systems
 - Placing subverted individuals into privileged positions within the organization
 - Installing sniffers or scanning devices on targeted networks and systems
 - Inserting tampered hardware or critical components into organizational systems or supply chains
4. Exploit and compromise: The adversary takes advantage of information and systems in order to compromise them, which may involve the following actions:
 - Split tunneling or gaining physical access to organizational facilities
 - Exfiltrating data or sensitive information
 - Exploiting multitenancy in a cloud environment
 - Launching zero-day exploits

Generalized Attack Process

5. Conduct an attack: The adversary coordinates attack tools or performs activities that interfere with organizational functions. Potential methods of attack include:
 - Communication interception or wireless jamming attacks
 - Denial-of-service (DoS) or distributed denial-of-service (DDoS) attacks
 - Remote interference with or physical attacks on organizational facilities or infrastructures
 - Session-hijacking or man-in-the-middle attacks
6. Achieve results: The adversary causes an adverse impact, which may include:
 - Obtaining unauthorized access to systems and/or sensitive information
 - Degrading organizational services or capabilities
 - Creating, corrupting or deleting critical data

Generalized Attack Process

7. Maintain a presence or set of capabilities: The adversary continues to exploit and compromise the system using the following techniques:
 - Obfuscating adversary actions or interfering with intrusion detection systems (IDSs)
 - Adapting cyberattacks in response to organizational security measures
8. Coordinate a campaign: The adversary coordinates a campaign against the organization that may involve the following measures:
 - Multi-staged attacks
 - Internal and external attacks
 - Widespread and adaptive attacks

Nonadversarial Threat Events

- Although most attacks are the result of a coordinated effort, there are other events that can pose various risk to an organization. Some of the most common nonadversarial threat events are:
 - Mishandling of critical or sensitive information by authorized users
 - Incorrect privilege settings
 - Fire, flood, hurricane, windstorm or earthquake at primary or backup facilities
 - Introduction of vulnerabilities into software products
 - Pervasive disk errors or other problems caused by aging equipment

Malware and Attack Types

- Malware, also called malicious code, is software designed to gain access to targeted computer systems, steal information or disrupt computer operations.
- There are several types of malware, the most important being computer viruses, network worms and Trojan horses, which are differentiated by the way in which they operate or spread.
- The computer worm known as Stuxnet highlights malware's potential to disrupt supervisory control and data acquisition (SCADA) systems and programmable logic controllers (PLCs), typically used to automate mechanical processes in factory settings or power plants.
- Discovered in 2010, Stuxnet was used to compromise Iranian nuclear systems and software. It has three components:
 1. A worm that carries out routines related to the payload
 2. A link file that propagates copies of the worm
 3. A rootkit that hides malicious processes to prevent detection

Malware and Attack Types

- Other common types of malware include:
 - Viruses—A computer virus is a piece of code that can replicate itself and spread from one computer to another. It requires intervention or execution to replicate and/or cause damage.
 - Network worm—A variant of the computer virus, which is essentially a piece of self-replicating code designed to spread itself across computer networks. It does not require intervention or execution to replicate.
 - Trojan horses—A further category of malware is the Trojan horse, which is a piece of malware that gains access to a targeted system by hiding within a genuine application. Trojan horses are often broken down into categories reflecting their purposes.
 - Botnets—A botnet (a term derived from “robot network”) is a large, automated and distributed network of previously compromised computers that can be simultaneously controlled to launch large-scale attacks such as denial-of-service (DoS).

Malware and Attack Types

- A number of further terms are also used to describe more specific types of malware, characterized by their purposes. They include:
 - Spyware—A class of malware that gathers information about a person or organization without the knowledge of that person or organization.
 - Adware—Designed to present advertisements (generally unwanted) to users.
 - Ransomware—A class of extortive malware that locks or encrypts data or functions and demands a payment to unlock them.
 - Keylogger—A class of malware that secretly records user keystrokes and, in some cases, screen content.
 - Rootkit—A class of malware that hides the existence of other malware by modifying the underlying operating system.

Other Attack Types

- The MITRE Corporation publishes a catalogue of attack patterns known as Common Attack Pattern Enumeration and Classification (CAPEC) as “an abstraction mechanism for helping describe how an attack against vulnerable systems or networks is executed.”
- Some of the most common attack patterns are:
 - Advanced persistent threats—Complex and coordinated attacks directed at a specific entity or organization. They require an enormous amount of research and time, often taking months or even years to fully execute.
 - Backdoor—A means of regaining access to a compromised system by installing software or configuring existing software to enable remote access under attacker-defined conditions.
 - Brute force attack—An attack made by trying all possible combinations of passwords or encryption keys until the correct one is found.

Other Attack Types

- Buffer overflow—Occurs when a program or process tries to store more data in a buffer (temporary data storage area) than it was intended to hold. Although it may occur accidentally through programming error, buffer overflow is an increasingly common type of security attack on data integrity. In buffer overflow attacks, the extra data may contain codes type of security attack on data integrity.
- Cross-site scripting (XSS)—A type of injection in which malicious scripts are injected into otherwise benign and trusted web sites. XSS attacks occur when an attacker uses a web application to send malicious code, generally in the form of a browser side script, to a different end user.
- Denial-of-service (DoS) attack—An assault on a service from a single source that floods it with so many requests that it becomes overwhelmed and is either stopped completely or operates at a significantly reduced rate.

Other Attack Types

- Man-in-the-middle attack—An attack strategy in which the attacker intercepts the communication stream between two parts of the victim system and then replaces the traffic between the two components with the intruder's own, eventually assuming control of the communication.
- Social engineering—Any attempt to exploit social vulnerabilities to gain access to information and/or systems. It involves a “con game” that tricks others into divulging information or opening malicious software or programs.
- Phishing—A type of electronic mail (email) attack that attempts to convince a user that the originator is genuine, but with the intention of obtaining information for use in social engineering.
- Spear phishing—An attack where social engineering techniques are used to masquerade as a trusted party to obtain important information such as passwords from the victim.

Other Attack Types

- Spoofing–Faking the sending address of a transmission in order to gain illegal entry into a secure system.
- Structure Query Language (SQL) injection–When specially crafted user-controlled input consisting of SQL syntax is used without proper validation as part of SQL queries, it is possible to glean information from the database in ways not envisaged during application design.
- Zero-day exploit–A vulnerability that is exploited before the software creator/vendor is even aware of its existence.
- Cryptomining and Cryptojacking –Once hosts are compromised, attackers can monetize the hosts by using them to create cryptocurrency, or “cryptomining.” The anonymity and non-traceability of cryptocurrencies makes these attacks particularly attractive. Hijacking victim computers for cryptomining is often called “cryptojacking.”

Other Attack Types

- Executive Attacks, Bank Fraud, and Payroll Fraud—These attacks involve targeting organization executives, bank accounts, and payroll processes, with the goal of stealing money from organizational bank accounts. Executives may be impersonated online, with fraudulent orders sent to subordinates directing them to make bank transfers or payments.
- Consumer Scams—These attacks involve targeting consumers to get them to give up personal information like e-mail addresses or online accounts, or to get them to directly pay the attackers for fraudulent services such as computer repair, anti-virus installation, or telephone support.
- Advanced Persistent Threat (APT) Targeted Attacks—These attacks involve highly specialized cyberattacks designed to penetrate even the most ardent cyberdefenses for major corporations and government networks. Key to an APT attack is the factor of time. An APT attacker may take days, weeks, or months to fully penetrate their target and achieve their objective.

Other Attack Types

- Identity Theft—This attack involves targeting identity information such as home addresses, email addresses, account logins, credit card numbers, bank account numbers, and health care records. Some of this information (such as bank accounts) can be directly exploited for money, but more often, identity information is then sold on the black market to aggregators
- Espionage and Sabotage—These attacks involve penetrating victim networks to steal sensitive and proprietary information, or damage IT or physical systems. While these are often the objectives of nation-state and military attackers, they may also be the objectives of commercial cyberattackers seeking to steal competitors' techniques or technologies, or to hamper their businesses.

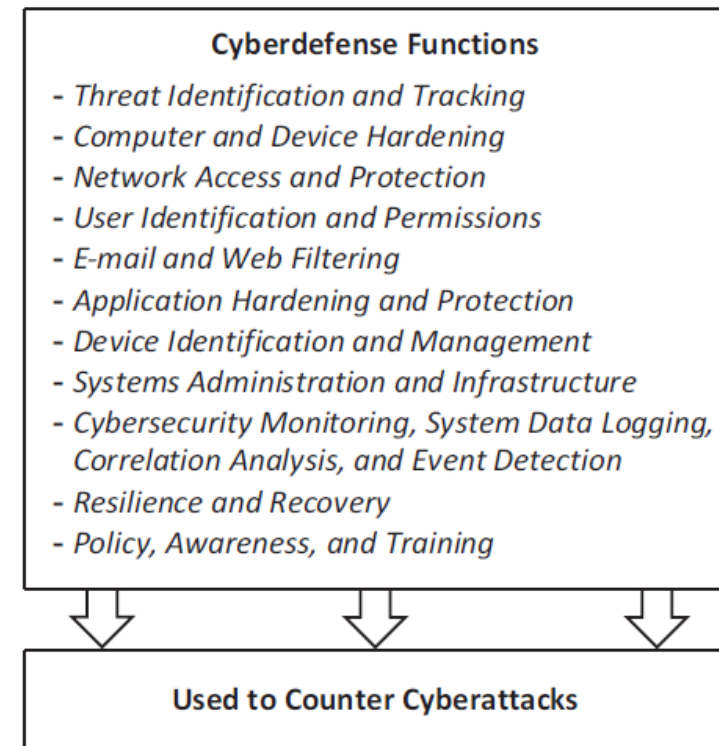
Cyberattacks



Source: ENISA Threat Landscape 2020

Cyberdefenses

- The old adage goes that “the attacker just has to succeed once, while the defender has to succeed every single time.”
- A successful cyberdefense can thwart attackers while also being resilient enough to continue working after some (or even most) of the cyberdefenses have failed or been defeated.
- Designing comprehensive, robust, and redundant cyberdefenses is part evidenced-based (i.e., part science) and part experience-based (i.e., part art).



Cyberdefenses

- Threat Identification and Tracking
 - Cyber threats may be characterized by indicators of compromise (IOCs) that identify malicious attacker activity in an organization. IOCs may include attacker accounts, computers, or network addresses that are identified using forensics.
 - Cyber threats may also be characterized by attacker tools, techniques, and procedures (TTPs) to include communications patterns, file hashes, or network protocols.
- Network Access and Protection
 - This function involves configuring computer networks to block potentially malicious access, restrict potentially malicious network traffic patterns, and detect potentially malicious network activity.
 - Some of the more common network protection techniques include secure configuration of routers and switches, installation of firewalls, network intrusion detection systems and intrusion prevention systems (IDS/IPS), access control gateways, and virtual private networks (VPNs).

Cyberdefenses

- Computer and Device Hardening
 - This function involves hardening individual computers and network-connected devices to make them more difficult to compromise with malware.
 - Anti-virus software is a common hardening technique, but is hardly the only approach.
 - Hardening may include using security technical implementation guides (STIGs) that specify security settings to configure and enable the most important computer and device security features.
- Network Access and Protection
 - This function involves configuring computer networks to block potentially malicious access, restrict potentially malicious network traffic patterns, and detect potentially malicious network activity.
 - Some of the more common network protection techniques include secure configuration of routers and switches, installation of firewalls, network intrusion detection systems and intrusion prevention systems (IDS/IPS), access control gateways, and virtual private networks (VPNs).

Cyberdefenses

- User Identification and Permissions
 - This function involves identifying, authenticating, and authorizing user access across the organization when accessing organizational networks, computers, and applications. Sometimes these activities are called identity and access management (IAM).
- E-Mail and Web Filtering
 - This function involves identifying and filtering e-mail and web traffic into and out of the organization.
 - For most organizations, e-mail and web browsing are the two main ways information enters and leaves the organization, as well as the main avenues for the delivery of malicious links, web pages, and software.
 - By analyzing and filtering this traffic, the organization can filter out unsolicited spam, many types of malware, and block access to inappropriate and malicious websites.

Cyberdefenses

- Application Hardening and Protection
 - This function involves protecting the organization's software and applications from compromise and malware.
 - This function includes deploying patches to update software, and identifying and remediating software vulnerabilities as they are discovered and where appropriate.
 - It may also include management of cryptography and keys used to encrypt data or authenticate communications.
- Device Identification and Management
 - This function involves identifying and tracking the devices (particularly the network- connected ones) used in the organization, and then managing those devices to ensure their safety and security.
- Systems Administration and Infrastructure
 - This function involves protecting the "behind-the-scenes" IT systems that underly and support the organization's other, more visible endpoints, servers, networks, and applications. This includes including monitoring, multifactor authentication, and network isolation.

Cyberdefenses

- Cybersecurity Monitoring, System Data Logging, Correlation Analysis, and Event Detection
 - This multifaceted function involves putting cybersecurity capabilities in place to detect cyberattack activity, and taking action when those capabilities indicate signs of malware or attacker activity.
 - This function involves monitoring organization systems, collecting system log data, correlating cybersecurity events or alerts, and detecting malicious cybersecurity behavior or events that warrant investigation.
- Policy, Awareness, and Training
 - This function involves making sure the people of the organization (and its partners, contractors, and consultants) understand the organization's cyberdefense objectives, and are prepared to do their parts to support those objectives.